UNIVERSIDAD NACIONAL AUTÓNOMA DE MÉXICO

FACULTAD DE INGENIERÍA

DIPLOMADO EN CIBERSEGURIDAD

MODULO 1.1 EL FACTOR HUMANO Y LA PROTECCIÓN.

PROYECTO 1: CASO DE ESTUDIO "INCIDENTE DE FUGA DE INFORMACIÓN"

ELABORÓ:

- BAUTISTA ORTEGA ELVIA
- FERREIRA ROJAS MAURICIO
- SALGADO VALDÉS ANDRÉS
- VÁZQUEZ ROMERO JESÚS

ÍNDICE

ÍNDICE **2**
INTRODUCCIÓN Y OBJETIVOS **3**
ANÁLISIS Y DISEÑO **4**
DESARROLLO **6**
Escenario 1: Falta de Tecnologías en Ciberseguridad y falta de empleados especializados en el área 6
Escenario 2: Filtración Intencionada 7
Escenario 3: Phishing o Ataque de Ingeniería Social 8
Escenario 4: Vulnerabilidad en los Sistemas de Acceso Remoto 8
Escenario 5: Fuga de Información por un Proveedor Externo 10
RESULTADOS **11**
CONCLUSIONES **12**
REFERENCIAS **13**

INTRODUCCIÓN Y OBJETIVOS

En el mundo empresarial, la seguridad de la información es fundamental para garantizar la continuidad y competitividad de la organización. La fuga de datos puede comprometer el desarrollo de productos, afectar la reputación corporativa y generar pérdidas económicas significativas. Por lo tanto, es importante comprender los riesgos asociados a la gestión de la información y a los sistemas tecnológicos empleados en nuestras empresas.

Se nos presenta un escenario en el que la empresa, tras desarrollar un producto innovador durante seis meses, descubre que otra empresa ha lanzado al mercado un diseño idéntico. Este incidente sugiere una posible filtración de información, lo que genera incertidumbre sobre las causas y los actores involucrados.

Este proyecto tiene como propósito examinar los posibles factores que contribuyeron a la fuga de información, identificar los sistemas y actores involucrados, y proponer estrategias para mitigar los riesgos de seguridad.

Como objetivos tenemos presentes:

- Identificar los posibles factores que originaron la fuga de información.
- Evaluar el impacto del incidente en los activos de la empresa.
- Proponer medidas correctivas y preventivas.

Y al lograr esto, podríamos obtener como beneficios para la empresa:

- Protección de la información confidencial.
- Fortalecimiento de la confianza empresarial.
- Reducción de riesgos legales y financieros.
- Optimización de los procesos internos (identificación de vulnerabilidades, por ejemplo).

ANÁLISIS Y DISEÑO

De acuerdo con el escenario planteado, se ha detectado que una empresa externa lanzó al mercado un producto con características idénticas a las de esta empresa. Es por ello que formulamos preguntas para cada sector dentro de la organización:

Cuerpo Empresarial u Organizativo:

- ¿Existen acuerdos de confidencialidad vigentes con empleados y colaboradores externos?
- ¿Cuáles son las políticas actuales de acceso a información confidencial?
- ¿Se ha realizado una auditoría sobre permisos y accesos a documentos sensibles?

Empleados y Personal Externo:

- ¿Hubo negligencia en el manejo de datos sensibles?
- ¿Algún empleado o proveedor compartió información de manera no autorizada?
- ¿Se han detectado ataques de ingeniería social (phishing, manipulación)?

Asimismo, consideramos que los factores que propiciaron la fuga de información fueron:

Cuerpo Empresarial u Organizativo:

- Falta de una clasificación de la información, considerando su valor para la organización, el impacto que puede generar su filtración y su nivel de sensibilidad, así como su almacenamiento en la red corporativa.
- Los errores o la falta de conocimiento y formación son otra de las causas más comunes de la fuga de información. Por un lado, el empleado debe utilizar los recursos que la organización pone a su disposición de forma responsable, como en el caso de los servicios en la nube, la navegación web, etc.
- Ausencia de procedimientos y el establecimiento de pautas y obligaciones para los trabajadores en el ámbito de la ciberseguridad. El establecimiento de

políticas que indiquen claramente a los usuarios cuáles son los límites dentro de los cuales deberán desempeñar su actividad y, por otro lado, los procedimientos para aquellas actividades de especial importancia o riesgo, disminuirán el riesgo de que se produzca una fuga de información.

- Acuerdos de confidencialidad de la información con los empleados. Es importante solicitar por escrito la conformidad con diversas normas internas, como la política de confidencialidad o de seguridad, entre otras, de manera que el futuro empleado deje por escrito la aceptación de las condiciones correspondientes.

Cuerpo Técnico:

- Ciberdelincuentes que pudieron explotar vulnerabilidades en la red o el acceso remoto. El código malicioso o malware es una de las principales amenazas, siendo el robo de información uno de sus objetivos más comunes.
- El acceso no autorizado a sistemas e infraestructuras es otra de las causas detrás del robo de información. Ya sea como parte de una campaña de desprestigio, o con motivo de sustraer información. Gran parte de estos accesos no autorizados se podrían evitar si los sistemas y aplicaciones estuvieran convenientemente actualizados. La actualización se considera parte fundamental de una buena aplicación, puesto que aporta mayor seguridad y denota un trabajo de mejora continua que redunda en beneficio de la aplicación y, por extensión, del usuario.

Aplicaciones y Sistemas Involucrados:

- **Red interna (LAN-WIFI):** Se requiere revisar los accesos no autorizados.
- **Uso de aplicaciones de comunicación y transferencia de archivos no controladas por la empresa:** Esto incluye aplicaciones como WhatsApp, Dropbox, Google Drive, correo electrónico personal, entre otras.
- **Sistemas de acceso remoto:** Se debe prestar atención al uso de VPN, RDP, SSH o credenciales comprometidas.

DESARROLLO

Al ser varios aspectos y situaciones que podrían suceder en este planteamiento, consideramos 5 escenarios en donde estarían involucrados varios roles así como activos físicos y lógicos afectados dentro de la organización,

Posibles Escenarios de Fuga de Información

Escenario 1: Falta de Tecnologías en Ciberseguridad y falta de empleados especializados en el área.

- **Roles involucrados:** La falta de conocimientos en ciberseguridad de los altos mandos de la empresa, especialmente aquellas que dependen de la tecnología, puede generar vulnerabilidades importantes. Esto podría traducirse como falta de preocupación por los riesgos que genera no implementar tecnologías de ciberseguridad y no contar con empleados especializados en el área. La empresa se vuelve más vulnerable a amenazas, tanto para prevenir cómo para corregir incidentes.
- **Procesos y sistemas afectados:**
    1. La falta de protocolos puede ocasionar la divulgación de información confidencial, a través de correos electrónicos, aplicaciones de mensajería o reuniones de trabajo remota.
    2. No tener protocolos claros puede ocasionar un acceso a la información a cualquier empleado o algún tercero que no debería tener autorización.
    3. La falta de protocolos puede hacer las redes vulnerables a ataques cómo malware, ransomware, etc.
    4. Los servidores y Bases de Datos se ven afectados a falta de protocolos que permitan administrar accesos, afectando la confidencialidad y la integridad de la información almacenada.
- **Activos afectados:**
    1. Activos lógicos. Los datos confidenciales pueden verse afectados, información de clientes y proveedores, datos financieros y de recursos humanos. También las credenciales de acceso están amenazadas, cómo nombres de usuarios, contraseñas.

2. Activos físicos. Dispositivos de trabajadores, o de usuarios finales, pueden estar comprometidos, también la infraestructura de red, instalaciones físicas, cómo el robo de equipos o dispositivos móviles.

- **Respuesta-Solución:** Contratación de especialistas en ciberseguridad, que realicen auditorías, mejoras a la seguridad de la Red y los Sistemas, capacitación y concientización del personal, actualizar Políticas y Procedimientos de seguridad.

Escenario 2: Filtración Intencionada

Roles involucrados:

- Un excolaborador pudo haber filtrado información antes de su salida debido a una mala relación con la empresa (de forma voluntaria).
- Un colaborador pudo haber filtrado información a cambio de un beneficio económico.
- Un proveedor de servicios pudo haber extraído información al finalizar su contrato con la empresa.

Procesos y sistemas afectados:

- Falta de asignación y revocación de permisos.
- Posible uso de dispositivos personales para almacenar información sensible.

Activos afectados:

- Documentos del diseño del producto.
- Código fuente y repositorios.
- Bases de datos con información de clientes y proveedores.

Respuesta-Solución:

- Auditar accesos y actividades recientes, revisando registros de acceso y bases de datos.
- Identificar descargas o envíos de documentos a direcciones desconocidas.

- Monitorear las actividades en tiempo real.

Escenario 3: Phishing o Ataque de Ingeniería Social

- **Roles involucrados:** Un empleado fue la víctima de un ataque de phishing, ocasionado la revelación de sus credenciales de acceso. El equipo de TI no pudo detectar a tiempo el acceso no autorizado, y los empleado de los recursos humanos no brindó suficiente capacitación en ciberseguridad al personal
- **Procesos y sistemas afectados:** El control de accesos a los sistemas internos de la empresa, gestión de credenciales en aplicación clave. El atacante pudo obtener acceso a los correos, a las bases de datos y a los archivos compartidos en internet.
- **Activos afectados:** Los servidores con datos especiales, credenciales de los usuarios, correos electrónicos con información confidencial y algunos documentos almacenados en la nube.
- **Respuesta-Solución:** Implementar un sistema de autenticación multifactor para evitar accesos no autorizados, capacitar periódicamente a los empleados sobre los ataques de ingeniería social, y utilizar herramientas de detección de phishing en los correos electrónicos.

Escenario 4: Vulnerabilidad en los Sistemas de Acceso Remoto

- **Roles involucrados:** Las vulnerabilidades comunes incluyen software desactualizado, configuraciones de seguridad incorrectas o vulnerabilidades sin solucionar. En este caso el personal Técnico como de TI, desarrolladores, personal de soporte técnico, con usuarios de accesos remotos, o atacantes externos.
- **Procesos y sistemas afectados:**
    1. VPN o conexiones RDP, SSH mal protegidas.
    2. Firewalls y políticas de acceso.
    3. Correos electrónicos (empresarial y no empresarial)
    4. Filtrado de contraseñas debido a su mala gestión.

- **Activos afectados:**

  Servidores, Computadoras que podrían ser el punto de fuga, equipos de red (routers switches), dispositivos de almacenamiento externos como Discos duros, USB, archivos compartidos en la red, Accesos administrativos comprometidos, código fuente de la aplicación

- **Respuesta-Solución:**
  1. Implementar VPNs seguras con autenticación multifactor.
  2. Realizar un análisis forense para identificar la línea de ataque
  3. Deshabilitar accesos remotos cuando no sean necesarios, aplicar parches de seguridad regularmente al igual que actualizaciones en las versiones de Software.
  4. Escanear regularmente redes y aplicaciones en busca de vulnerabilidades conocidas.
  5. Implementar firewalls robustos, sistemas de detección de intrusiones y otras medidas de seguridad para proteger contra el acceso no autorizado.
  6. Realizar pruebas de penetración para identificar y abordar posibles debilidades.

Escenario 5: Fuga de Información por un Proveedor Externo

- **Roles involucrados:** Los proveedores externos pueden ser el eslabón más débil de la cadena y convertirse en un ciberataque. En este escenario el proveedor externo con acceso a información crítica compartió datos con la competencia, ya sea por descuido o con intención.

  En este escenario entran los servicios contratados: alojamiento web para la tienda online, servicios de una gestoría y el soporte informático para las Apps.

- **Procesos y sistemas afectados:** La persona externa pudo recibir la información de parte de alguna otra persona, afectando al control de accesos a proveedores externos al mismo tiempo que debilitaba el sistema de transmisión de seguridad.
- **Activos afectados:**
  1. Control de accesos
  2. Diseño y especificaciones de la aplicación.
  3. Políticas de confidencialidad con terceros
- **Respuesta-Solución:** .
  1. Delimitar accesos ya que los proveedores sólo necesitan acceso a la aplicación específica que brinda el servicio.
  2. Implementar auditorías periódicas sobre proveedores con acceso a información sensible.
  3. Restringir el acceso de proveedores a la información mínima necesaria al mismo tiempo que se realiza el monitoreo de accesos y actividades en tiempo real
  4. asegurarse de que los proveedores aplican los protocolos de seguridad adecuados, cambiar contraseñas por defecto o compartidas, verificación de las actualizaciones y parches de seguridad.

RESULTADOS

Con base a lo anterior, podemos notar una serie de similitudes en cuanto a la respuesta o soluciones que podría tomar la empresa con respecto a los distintos escenarios propuestos en nuestro equipo, es por ello que a continuación desglozaremos de manera general las posibles soluciones y el cómo es que debería actuar la empresa, ya que los momentos inmediatamente posteriores a la detección de un incidente de fuga de información, en este caso la aplicación empresarial, son especialmente críticos y una adecuada gestión en las primeras fases puede suponer una reducción del impacto.

Cifrado: Implementar protocolos de cifrado para proteger datos sensibles tanto en reposo como en tránsito. El cifrado convierte la información en un formato ilegible, haciéndola inútil para individuos no autorizados, incluso si acceden a ella.

Controles de Acceso: Implementar controles de acceso estrictos y permisos de usuarios para limitar quién puede ver, editar o compartir datos sensibles. Revisar regularmente los privilegios de acceso para asegurarse de que se alineen con las responsabilidades laborales y las necesidades del negocio.

Auditorías Regulares: Realizar auditorías de seguridad regularmente para identificar y abordar vulnerabilidades que podrían llevar a fugas de datos. Esto incluye revisar configuraciones del sistema, registros de acceso y permisos de usuario.

Capacitación de Empleados: Educar a los empleados sobre las mejores prácticas de seguridad de datos y la importancia de proteger la información confidencial. Proveer capacitación regular sobre temas como higiene de contraseñas, reconocimiento de intentos de phishing, y procedimientos seguros de manejo de datos.

Plan de Respuesta a Incidentes: Desarrollar y probar un plan de respuesta a incidentes que detalle los pasos a seguir en caso de una fuga de datos. Esto incluye procedimientos para contención, investigación, comunicación y remediación.

CONCLUSIONES

El filtrado de información representa un riesgo crítico para cualquier organización, ya que puede derivar en pérdidas económicas significativas, daños irreparables a la reputación de la empresa e incluso su cierre definitivo. Las causas de estos incidentes pueden ser variadas, incluyendo errores humanos, ataques cibernéticos, vulnerabilidades en sistemas de seguridad, accesos no autorizados o incluso la acción intencionada de empleados desleales.

Para mitigar estos riesgos, es fundamental que las organizaciones adopten una estrategia de seguridad integral que abarque tanto medidas preventivas como planes de respuesta rápida ante incidentes. Entre las acciones preventivas más eficaces se encuentran la implementación de tecnologías avanzadas como firewalls, sistemas de detección y prevención de intrusiones, encriptación de datos, autenticación multifactor y monitoreo continuo de redes y sistemas.

Sin embargo, la tecnología por sí sola no es suficiente. La cultura de seguridad dentro de la organización juega un papel clave en la protección de la información. Esto implica educar y concienciar a todos los empleados sobre las mejores prácticas de ciberseguridad, la identificación de amenazas potenciales y la importancia de seguir estrictamente los protocolos establecidos. La capacitación regular y la simulación de ataques pueden ayudar a fortalecer la preparación del equipo ante posibles incidentes.

Además, es esencial que las empresas establezcan políticas de seguridad de la información claras y actualizadas, alineadas con normativas y estándares internacionales. Estas políticas deben definir aspectos como la clasificación y acceso a la información, la gestión de incidentes, el uso de dispositivos personales dentro de la red corporativa y las responsabilidades de cada empleado en la protección de los datos.

En caso de que se produzca un filtrado de información, una respuesta rápida y efectiva puede minimizar el impacto negativo. Para ello, las organizaciones deben contar con planes de contingencia y protocolos de acción que incluyan la

identificación inmediata del incidente, la contención del daño, la comunicación con las partes afectadas y la implementación de medidas correctivas para evitar que la situación se repita.

REFERENCIAS

- *Cómo gestionar una fuga de información. Una guía de aproximación al empresario*. (s/f). Incibe.es. Recuperado el 14 de marzo de 2025, de https://www.incibe.es/empresas/guias/guia-fuga-informacion

- Santander, B. (s/f). *Fuga de datos*. Banco Santander. Recuperado el 14 de marzo de 2025, de https://www.bancosantander.es/glosario/fuga-datos

- *Trabajo desde casa: Riesgos de Ciberseguridad en evolución*. (s/f). Fortinet. Recuperado el 14 de marzo de 2025, de https://www.fortinet.com/lat/resources/cyberglossary/work-from-home-cybersecurity-risks

- Cómo Evitar Filtraciones de Datos Empresariales a Través de Proveedores y Terceros: La Amenaza Invisible -. *OpenSecurity*. Sánchez, M. (2025, March 12). Recuperado el 14 de marzo de 2025, de https://www.opensecurity.es/como-evitar-filtraciones-de-datos-empresariales-a-traves-de-proveedores-y-terceros-la-amenaza-invisible/

- ¿Qué es una filtración de datos? - Términos y definiciones de ciberseguridad. (n.d.).Recuperado el 14 de marzo de 2025, de ¿Qué es una filtración de datos? - Términos y definiciones de ciberseguridad

- ¿Qué es la fuga de información ? | Centro Universitario de Tecnología y Arte Digital. U-tad. U-Tad. (2024, May 7). Recuperado el 14 de marzo de 2025, de https://u-tad.com/que-es-la-fuga-de-informacion/

- *Todo sobre Fuga de Información y Clasificación de Datos - NextVision*. NextVision. Berardi, A. (2017, December 15). Recuperado el 14 de marzo de 2025, de

https://nextvision.com/todo-sobre-fuga-de-informacion-y-clasificacion-de-datos/